Sicurezza quantistica

Paper di riferimento

https://www.semanticscholar.org/paper/Toward-Generating-a-New-Intrusion-Detection-Dataset-Sharafaldin-Lashkari/a27089efabc5f4abd5ddf2be2a409bff41f31199

DataSet di Riferimento

IDS 2017 | Datasets | Research | Canadian Institute for Cybersecurity | UNB

CIC and ISCX datasets are used for security testing and malware prevention. IDSs and IPSs are important defense tools against sophisticated network attacks.

https://www.unb.ca/cic/datasets/ids-2017.html

📄 Toward Generating a New Intrusion Detection Dataset and Intrusion Traffic Characterization

> **Autori:** Iman Sharafaldin, Arash Habibi Lashkari, Ali A. Ghorbani
> **Istituzione:** Canadian Institute for Cybersecurity (CIC), University of New Brunswick (UNB), Canada
> **Conferenza:** ICISSP 2018 – 4th International Conference on Information Systems Security and Privacy

---

🎯 Obiettivo del Paper

Il paper affronta due problemi centrali nella ricerca sugli Intrusion Detection Systems (IDS):

1. **Mancanza di dataset adeguati** per l'addestramento e la valutazione di sistemi IDS anomaly-based.
2. **Obsolescenza e incompletezza** dei dataset esistenti (DARPA98, KDD99, ISCX2012, ADFA13, ecc.).

La soluzione proposta è **CICIDS2017**, un nuovo dataset pubblicamente disponibile che:

- Contiene traffico **benigno** e **7 famiglie di attacchi** comuni
- Soddisfa **11 criteri** per la validità di un dataset IDS
- Include oltre **80 feature** estratte dai flussi di rete

🗂️ Sezione 1 — Introduzione

Problema

- Gli IDS e IPS sono difese critiche contro attacchi sempre più sofisticati.
- I dataset esistenti spesso:
  - Sono **obsoleti** (non riflettono il traffico attuale)
  - Sono **anonimizzati** (payload rimossi)
  - Mancano di **diversità negli attacchi**
  - Non hanno **metadati** o **feature set** completi

Framework di valutazione (11 caratteristiche critiche)

> Proposto da Gharib et al. (2016)

#	Caratteristica
1	Attack Diversity
2	Anonymity
3	Available Protocols

#	Caratteristica
4	Complete Capture
5	Complete Interaction
6	Complete Network Configuration
7	Complete Traffic
8	Feature Set
9	Heterogeneity
10	Labelling
11	Metadata

Contributi del paper

- ✅ Generazione del dataset **CICIDS2017** (copre tutti gli 11 criteri)
- ✅ Analisi delle **feature** più discriminative per ogni tipo di attacco
- ✅ Valutazione di **7 algoritmi di machine learning** sul dataset

---

🗂️ Sezione 2 — Dataset Esistenti (Analisi Critica)

Dataset	Anno	Problemi principali
DARPA	1998–99	No traffico reale, assenza di falsi positivi, obsoleto
KDD'99	1998–99	Record ridondanti, corruzione dei dati, ambienti simulati
DEFCON	2000–02	Solo traffico da competizioni CTF, non realistico
CAIDA	2002–16	Molto specifico, payload anonimizzato
LBNL	2004–05	No payload, forte anonimizzazione
CDX	2009	Poca diversità di traffico e volume
KYOTO	2009	Solo honeypot, no falsi positivi, traffico normale simulato
TWENTE	2009	Poco volume, traffico ambiguo (né benigno né malevolo)
UMASS	2011	Scenario singolo TCP, non adatto per IDS

Dataset	Anno	Problemi principali
ISCX2012	2012	No HTTPS (70% del traffico moderno), attacchi non realistici
ADFA	2013	Poca diversità, comportamenti normali/attacchi non separati

> ⚠️ **Nessuno** dei dataset precedenti soddisfa tutti gli 11 criteri.

🗂️ Sezione 3 — Architettura del Testbed

Obiettivo

Creare un ambiente di test realistico con due reti completamente separate:

- **Victim-Network** → infrastruttura sicura con traffico benigno reale
- **Attack-Network** → infrastruttura offensiva per lanciare gli attacchi

---

🖥️ Victim-Network

Composta da: **1 Firewall (Fortinet)**, **2 Switch**, **3 Server**, **10 PC**, gestiti da un Domain Controller (DC) con Active Directory.

Macchina	OS	IP Privato	IP Pubblico
Server DC/DNS	Windows Server 2016	192.168.10.3	—
Web Server	Ubuntu 16	192.168.10.50	205.174.165.68
Server 2	Ubuntu 12	192.168.10.51	205.174.165.66
PC	Ubuntu 14.4 (32/64)	192.168.10.19 / .17	—
PC	Ubuntu 16.4 (32/64)	192.168.10.16 / .12	—
PC	Windows 7 Pro	192.168.10.9	—
PC	Windows 8.1 (64-bit)	192.168.10.5	—
PC	Windows Vista	192.168.10.8	—
PC	Windows 10 Pro (32/64)	192.168.10.14 / .15	—
PC	macOS	192.168.10.25	—
Firewall	Fortinet	—	—

> 🔍 Una porta dello switch principale è configurata come **mirror port** per catturare tutto il traffico in entrata e uscita.

💀 Attack-Network

Composta da: **1 Router**, **1 Switch**, **4 PC** con IP pubblici.

Macchina	OS	IP Pubblico
PC 1 (attaccante principale)	Kali Linux	205.174.165.73
PC 2	Windows 8.1	205.174.165.69
PC 3	Windows 8.1	205.174.165.70
PC 4	Windows 8.1	205.174.165.71

👤 Benign Profile Agent (B-Profile)

Sistema sviluppato in **Java** per generare traffico benigno naturalistico e realistico.

- Profila il comportamento astratto di **25 utenti reali**
- Protocolli simulati: **HTTP, HTTPS, FTP, SSH, Email**
- Feature estratte per ogni profilo:
  - Distribuzione delle dimensioni dei pacchetti per protocollo
  - Numero di pacchetti per flusso
  - Pattern nel payload
  - Dimensione del payload
  - Distribuzione dei tempi di richiesta

⚔️ Profili di Attacco (6 famiglie)

Attacco	Descrizione sintetica
Brute Force	Tentativi ripetuti su password (FTP, SSH, HTTP). Tool: Patator
Heartbleed	Exploit del bug OpenSSL (CVE-2014-0160) tramite heartbeat malformato. Tool: Heartleech

Attacco	Descrizione sintetica
Botnet	Rete di dispositivi compromessi per furto dati, spam, accesso remoto. Tool: Ares
DoS	Flood di richieste per rendere indisponibile un servizio. Tool: Slowloris, Hulk, GoldenEye, Slowhttptest
DDoS	Come DoS ma da sistemi multipli coordinati (es. botnet). Tool: LOIC
Web Attack	SQL Injection, XSS, Brute Force HTTP su app vulnerabile (DVWA). Tool: Selenium
Infiltration	Exploit via file infetto → backdoor → port scan interno. Tool: Metasploit + Nmap

---

🗂️ Sezione 4 — Dataset CICIDS2017

Periodo di cattura

> Dal **lunedì 3 luglio** alle 09:00 al **venerdì 7 luglio** alle 17:00 (5 giorni continui)

Calendario degli attacchi

Giorno	Etichette / Attacchi
Lunedì	Solo traffico benigno
Martedì	Brute Force FTP (mattina), Brute Force SSH (pomeriggio)
Mercoledì	DoS (Slowloris, Slowhttptest, Hulk, GoldenEye) + Heartbleed
Giovedì	Web Attack (Brute Force HTTP, XSS, SQL Injection) + Infiltration
Venerdì	DDoS LOIC + Botnet ARES + PortScan (Nmap, tutti gli switch)

Profili di attacco

💥 Brute Force

- **Tool:** Patator (multi-threaded, Python)
- **Target:** FTP e SSH sull'Ubuntu 16.04 (web server)
- **Attaccante:** Kali Linux

🩸 Heartbleed

- **Vulnerabilità:** OpenSSL 1.0.1f (CVE-2014-0160)
- **Tool:** Heartleech
- **Effetto:** Dump della memoria del processo del web server

🤖 Botnet

- **Tool:** Ares (Python, remote shell, keylogger, screenshot)
- **Target:** 5 macchine Windows (Vista, 7, 8.1, 10 32-bit, 10 64-bit)

🚫 DoS

- **Tool:** Slowloris, Slowhttptest, Hulk, GoldenEye
- **Tecnica:** Connessioni multiple con bandwidth minima per esaurire risorse
- **Target:** Ubuntu 16.04 con Apache

🌊 DDoS

- **Tool:** LOIC (Low Orbit Ion Canon)
- **Tecnica:** Flood UDP/TCP/HTTP da sistemi multipli
- **Target:** Ubuntu 16 (web server)

🌐 Web Attack

- **Ambiente:** DVWA (Damn Vulnerable Web App, PHP/MySQL)
- **Attacchi:** SQL Injection, XSS (automatizzati con Selenium), Brute Force HTTP

🕵️ Infiltration

- **Tool:** Metasploit
- **Tecnica:** Vittima scarica file infetto (Dropbox per Windows, USB per Mac) → backdoor → Nmap port scan sull'intera rete

---

🗂️ Sezione 5 — Analisi

Metodologia in 4 fasi

1. Estrazione di **80 feature** tramite **CICFlowMeter**
2. Selezione delle feature ottimali con **RandomForestRegressor** (scikit-learn)
3. Valutazione con **7 algoritmi ML**
4. Verifica degli 11 criteri di qualità

Feature più importanti per attacco

Attacco	Feature chiave
DoS GoldenEye	B.Packet Len Std, Flow IAT Min, Fwd IAT Min
Heartbleed	B.Packet Len Std, Subflow F.Bytes, Flow Duration
DoS Hulk	B.Packet Len Std, Flow Duration, Flow IAT Std
DoS Slowhttp	Flow Duration, Active Min, Active Mean
DoS Slowloris	Flow Duration, F.IAT Min, B.IAT Mean
SSH-Patator	Init Win F.Bytes, Subflow F.Bytes, ACK Flag Count
FTP-Patator	Init Win F.Bytes, F.PSH Flags, SYN Flag Count
Web Attack	Init Win F.Bytes, Subflow F.Bytes, Init Win B.Bytes
Infiltration	Subflow F.Bytes (4.30!), Total Len F.Packets, Flow Duration
Bot	Subflow F.Bytes, Total Len F.Packets, F.Packet Len Mean
PortScan	Init Win F.Bytes, B.Packets/s, PSH Flag Count
DDoS	B.Packet Len Std, Avg Packet Size, Flow Duration

Metriche di valutazione

Precision (Pr) = TP / (TP + FP)
Recall (Rc) = TP / (TP + FN)
F1-Score = 2 / (1/Pr + 1/Rc)

Risultati degli algoritmi ML

Algoritmo	Precision	Recall	F1	Tempo (sec)
KNN	0.96	0.96	0.96	1908.23
Random Forest	0.98	0.97	0.97	**74.39** ⭐

Algoritmo	Precision	Recall	F1	Tempo (sec)
ID3	0.98	0.98	**0.98**	235.02
Adaboost	0.77	0.84	0.77	1126.24
MLP	0.77	0.83	0.76	575.73
Naive Bayes	0.88	0.04	0.04	14.77
QDA	0.97	0.88	0.92	18.79

> 🏆 **Migliore algoritmo complessivo: Random Forest** — ottima accuratezza con tempo di esecuzione minimo.

🗂️ Sezione 6 — Conclusioni

CICIDS2017 vs. Dataset precedenti — Criteri soddisfatti

Criterio	CICIDS2017	Tutti i precedenti
Network Traffic	✅	Parziale
Labelling	✅	Parziale
Complete Interaction	✅	❌ (mai tutti)
Complete Capture	✅	Parziale
Available Protocols (HTTP, HTTPS, SSH, FTP, Email, Browser)	✅	Parziale
Attack Diversity (BForce, DoS, Scan, Botnet, DNS, altri)	✅	Parziale
Anonymity	✅	Parziale
Heterogeneity	✅	Parziale
Features (80+)	✅	Parziale
Metadata	✅	Parziale

> 📌 **CICIDS2017 è il primo dataset a soddisfare tutti gli 11 criteri.**

Lavori futuri

- Aumentare il numero di macchine nella rete
- Includere attacchi più aggiornati

🔗 Risorse

- 📦 **Dataset:** http://www.unb.ca/cic/datasets/IDS2017.html
- 🛠️ **CICFlowMeter:** Disponibile sul sito del Canadian Institute for Cybersecurity

---

> 📝 *Finanziato da ACOA (Atlantic Innovation Fund) e NSERC Canada.*